NIST Cybersecurity Framework - Smart Campus Lab

Student Name
Razn Alshahrani
Team member 1
Team member 2
Team member 3
Team member 4

Scenario: Smart Campus Lab (Default)
A university lab hosting student apps and IoT prototypes with 20 staff and 200 students. The environment includes BYOD (Bring Your Own Device) and cloud-based systems. Assume moderate risk appetite and limited budget.

NIST Function (all of them)	Category (select 1 per function)	Subcategory (select 1 per category)	Current Profile (at least 1 state)	Target Profile after 1 year (at least 1 state)	Prioritized action plan (at least 2)
Identify	Asset Management (ID.AM)	ID.AM-1: Physical devices and systems are inventoried	Devices tracked manually by spreadsheets. Some devices not registered. No real-time visibility.	Centralized asset management system in use. Automated inventory updates. All devices linked to user IDs.	1. Deploy an asset inventory tool with automatic discovery. 2. Require device registration before network access. 3. Conduct quarterly inventory audits.

Protect	Access Control (PR.AC)	PR.AC-1: Identities and credentials are managed	Shared accounts still used. Weak passwords without expiry. No MFA applied.	MFA enabled for all staff and students. Role-based access control (RBAC) applied. Accounts reviewed quarterly.	1. Implement multi-factor authentication for all systems. 2. Enforce strong password and rotation policy. 3. Conduct periodic access reviews.
Detect	Security Continuous Monitoring (DE.CM)	DE.CM-1: Continuous monitoring of the network to identify potential security incidents.	Network monitoring is currently manual and limited. There is no automated detection or alerting for unusual activities.	All network activity is monitored continuously and centrally. Suspicious activities automatically trigger alerts, and IT staff regularly review the logs.	1.Alerts are automatically generated for any suspicious activities, such as failed login attempts or unusual network traffic. 2.Logs are routinely checked by IT staff, who act immediately on any triggered alerts.

Response	Response Planning (RS.RP)	RS.RP-1: A formal incident response plan is in place and actively followed whenever a security event occurs.	Currently, the organizatio n lacks a formal incident response plan, and IT staff respond to security events in an unstructure d manner, causing some delays in handling incidents.	A formal incident response plan is established and actively followed. IT staff are trained, and incidents are documente d.	1.Develop and formalize an incident response plan for all potential security incidents. 2.Ensure IT staff are trained to follow the plan and document each incident and response accurately.
Recover	Recovery Plan (RC.RP)	RC.RP-1: Recovery plans are executed during or after cybersecurity incidents.	1.Backups are stored on-site locally organizati on 2.No real time backup.	1.Impleme nt off site backups offline or cloud based 2.Enforce Weekly backups	1.Develop recovery plan and testing and tested every 6 months. 2.Define Recovery Time Objectives (RTO) to set the time limits for system recovery and data loss 3.Implementi ng Post-Incident Activity After recovery conduct a review to analyze the

					incident response and recovery process and document lessons learned during or after cybersecurity incidents to improve future responses